



CCS6344-DATABASE AND CLOUD SECURITY

Assignment 1: Database Security

Trimester 2610

By Group 19

Dr. Navaneethan A/L C. Arjuman

Lecture session: TC1L

Name	ID
Willie Teoh Chin Wei	1211106712
Lam Rong Yi	1211107112
Lee Yu Jie	

Video Link:

GitHub Link: <https://github.com/WANNABE003/Database-Cloud-Security-TC1L-G19>

Table of Contents

1. Proposal of the Application.....	3
1.1 Objective.....	3
1.2 Proposed design and implementation of the application.....	3
1.3 Proposed hardware and software to develop the application.....	4
1.4 System Design and Database Design.....	4
1.5 Securing Database.....	6
2. Implementation of the application using SQL Database.....	7
2.1 SQL Database Design.....	7
2.1.1 AppUser Table.....	8
2.1.2 Product Table.....	8
2.1.3 CustomerOrder Table.....	8
2.1.4 OrderItem Tables.....	8
2.1.5 AuditLog Table.....	8
3. Threat Modelling.....	9
4. PDPA 2010.....	10
4.1 Categorization with PDPA For Personnel.....	10
4.2 Data Lifecycle Mapping PDPA2010 Requirement.....	11
5. Security Measures Implementation.....	12

Secure Fashion E-Commerce Management System

1. Proposal of the Application

1.1 Objective

1. **Primary Goal:** To develop a secure web-based fashion e-commerce management system using a SQL database.
2. **Key Objective:**
 1. To protect customer personal data, order records, and fashion product inventory.
 2. To ensure confidentiality, integrity, and availability using database security controls.
 3. To implement role-based access for customers, inventory officers, and administrators.
 4. To apply SQL Server security features such as roles, views, dynamic data masking, row-level security, triggers, auditing, and backup.
 5. To align the handling of customer personal data with PDPA 2010 requirements.

1.2 Proposed design and implementation of the application

The Secure Fashion E-Commerce Management System, named SecureStyle, is designed for an online boutique that sells clothing, bags, and fashion accessories. The system supports three main user roles: Customer, Inventory Officer, and Admin.

- **User Login System**

Users authenticate using email and password. Passwords are compared against bcrypt password hashes stored in the SQL database. After successful login, the system assigns access based on the user role.
- **Fashion Inventory Management**

Inventory officers can add fashion products such as dresses, blazers, skirts, bags, and accessories. Admin users can delete products when they are discontinued or no longer available.
- **Customer Order Management**

Customers can view active products and create orders. Order data is stored in the SQL database and linked to the customer account.
- **Security Evidence Dashboard**

Admins can view audit logs. Authorized staff can view masked customer records to demonstrate Dynamic Data Masking and least privilege access.

The system design contains several key modules:

1. **Customer Module:** Allows customers to browse products and place orders.
2. **Inventory Officer Module:** Allows staff to add and manage fashion product stock.
3. **Admin Module:** Allows administrators to delete products and monitor audit logs.

Security evidence such as audit logs and masked customer data is included under the Admin and authorized staff functions. It is a security feature of the system, not a separate user role.

1.3 Proposed hardware and software to develop the application

The proposed technologies to be used in this application are as follows:

Component	Proposed Technology	Justification
Frontend	HTML, CSS, JavaScript	Simple browser-based interface for screenshots and testing
Backend	Node.js with Express.js	Handles API routing, authentication, validation, and database communication
Database	Microsoft SQL Server	Supports SQL roles, views, masking, row-level security, triggers, backup, and encryption
Database Tool	SQL Server Management Studio (SSMS)	Used to run SQL scripts, inspect tables, and capture database evidence
Server OS	Windows Server or Windows VM in Oracle VirtualBox	Suitable for SQL Server, SSMS, and assignment demonstration
Container Option	Docker	Provides repeatable SQL Server and application environment
Security Libraries	bcryptjs, jsonwebtoken, helmet, express-rate-limit, zod, mssql	Used for password hashing, sessions, headers, brute-force protection, validation, and parameterized SQL

1.4 System Design and Database Design

- **System Design**

The system uses a three-tier architecture. The browser provides the user interface, the Node.js Express server manages business logic and security checks, and Microsoft SQL Server stores application data.

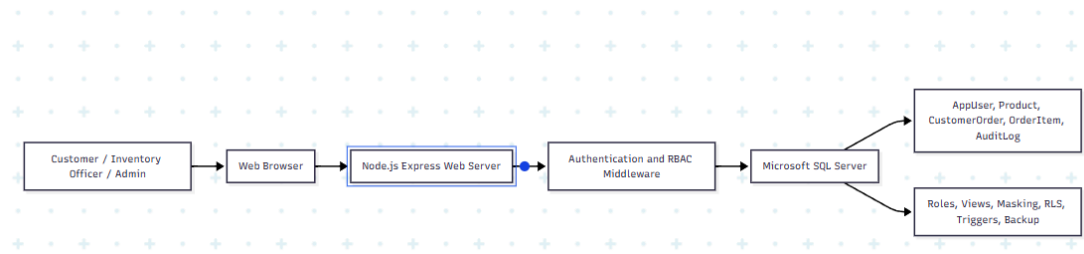


Figure 1.4.1 System Architecture

- **Database Design**

The database has the following structure:

- Key tables:

1. **AppUser table:** Stores user details, roles, contact information, addresses, and password hashes.
2. **Product table:** Stores fashion product details such as name, SKU, price, stock quantity, category, and active status.
3. **CustomerOrder table:** Stores order details including customer, total amount, order status, and masked shipping address.
4. **OrderItem table:** Stores products and quantities linked to each order.
5. **AuditLog table:** Logs user actions such as login, product creation, product deletion, and order creation.



Figure 1.4.2 ERD Diagram

1.5 Securing Database

Authentication and Authorization: The application validates users through email and password login. Role-based access ensures that customers, inventory officers, and admins can only access functions assigned to their roles.

Password Hashing: User passwords are hashed using bcrypt before storage. This prevents plaintext password exposure if the database is compromised.

Role-Based Access Control (RBAC): The backend uses role checks such as Admin-only delete access and InventoryOfficer/Admin product insert access.

SQL Roles and Permissions: SQL Server roles are created for CustomerRole, InventoryOfficerRole, and AdminRole. GRANT and DENY permissions restrict direct table access.

Row-Level Security (RLS): RLS is used to restrict customer order visibility so customers can only access their own orders, while admins can view all orders.

Dynamic Data Masking (DDM): Sensitive fields such as phone number, address, and shipping address are masked to reduce unnecessary exposure.

SQL Injection Prevention: The application uses parameterized SQL queries through the mssql driver instead of string-concatenated SQL.

Auditing and Triggers: The AuditLog table records important activities. SQL triggers log product and order changes for accountability.

Backup: The database backup command creates a recoverable database backup with checksum and compression.

Transparent Data Encryption (TDE) Plan: TDE is included as a database-at-rest encryption plan. It protects database files if unauthorized access occurs at the storage level.

2. Implementation of the application using SQL Database

2.1 SQL Database Design

The application uses a securely designed SQL database with relational tables, primary keys, foreign keys, constraints, masking, views, triggers, and audit logs.

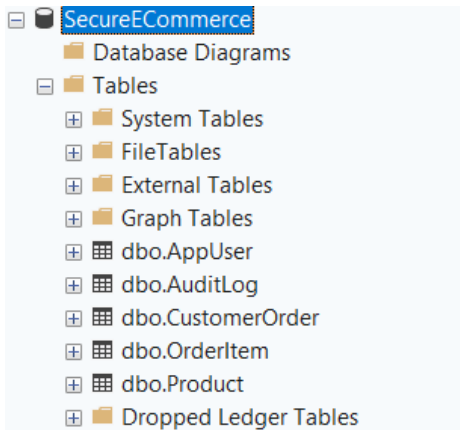


Figure 2.1: Screenshot of database tables in SSMS.

2.1.1 AppUser Table

The AppUser table stores registered users. It includes UserID, role, email, name, phone number, address, password hash, account status, and timestamps. Passwords are not stored in plaintext. Sensitive personal information is protected using Dynamic Data Masking.

	UserID	Role	Email	FirstName	LastName	PhoneNumber	AddressLine1	City	State	Postcode	PasswordHash
1	USR-ADMIN-001	Admin	admin@securecart.local	Willie Teoh	Chin Wei	0123456789	Cyberjaya Office, Persiaran Multimedia	Cyberjaya	Selangor	63000	\$2a\$10\$VUkpRGYNXtKh9yFjanReB8mYDGAU0
2	USR-CUST-001	Customer	customer@securecart.local	Lee	Yu Jie	0145556677	12 Jalan Harmoni	Kuala Lumpur	WP Kuala Lumpur	50480	\$2a\$10\$VUkpRGYNXtKh9yFjanReB8mYDGAU0
3	USR-OFFICER-001	Inventory Officer	officer@securecart.local	Lam	Rong Yi	0132223344	Warehouse A, Jalan Teknologi	Petaling Jaya	Selangor	47810	\$2a\$10\$VUkpRGYNXtKh9yFjanReB8mYDGAU0

Figure 2.1.1: Sample records from the AppUser table.

2.1.2 Product Table

The Product table stores fashion product information such as product ID, product name, SKU, price, stock quantity, category, active status, and creator ID. The table uses constraints to prevent invalid price and stock values.

	ProductID	Name	SKU	Price	StockQty	Category	IsActive	CreatedBy	CreatedAt	UpdatedAt
1	PRD-BAG-001	Quilted Mini Crossbody Bag	SKU-BAG-001	159.00	25	Bags	1	USR-OFFICER-001	2026-05-20 02:56:20.5313107	NULL
2	PRD-BLAZER-001	Tailored Linen Blazer	SKU-BLZ-001	269.90	14	Outerwear	1	USR-OFFICER-001	2026-05-20 02:56:20.5313107	NULL
3	PRD-DRESS-001	Satin Evening Slip Dress	SKU-DRS-001	229.90	20	Dresses	1	USR-OFFICER-001	2026-05-20 02:56:20.5313107	NULL

Figure 2.1.2 Sample record from the Product Table

2.1.3 CustomerOrder Table

The CustomerOrder table records customer orders, total amount, order status, and masked shipping address.

	OrderID	UserID	TotalAmount	Status	ShippingAddress	CreatedAt	UpdatedAt
1	ORD-1779330712525	USR-CUST-001	477.00	Pending	12 Jalan Harmoni, Kuala Lumpur	2026-05-21 02:31:52.5615279	NULL
2	ORD-1779330828728	USR-CUST-001	477.00	Pending	12 Jalan Harmoni, Kuala Lumpur	2026-05-21 02:33:48.7316568	NULL
3	ORD-SAMPLE-001	USR-CUST-001	229.90	Paid	12 Jalan Harmoni, Kuala Lumpur	2026-05-20 02:56:20.5436205	NULL

Figure 2.1.3 Sample record from CustomerOrder Table

2.1.4 OrderItem Tables

The OrderItem table stores the ordered products, quantity, and unit price. Foreign keys maintain relationships between users, orders, and products.

	OrderItemID	OrderID	ProductID	Quantity	UnitPrice
1	1	ORD-SAMPLE-001	PRD-DRESS-001	1	229.90
2	2	ORD-1779330712525	PRD-BAG-001	3	159.00

Figure 2.1.4 Sample record from the OrderItem table

2.1.5 AuditLog Table

The AuditLog table records key actions such as login attempts, product creation, product deletion, and order creation. It stores the actor, role, action, target, status, timestamp, and IP address.

	AuditID	EventTime	ActorID	ActorRole	Action	TargetType	TargetID	Status	IpAddress
1	1	2026-05-20 02:56:20.5640519	USR-OFFICER-001	InventoryOfficer	SeedProductCreated	Product	PRD-DRESS-001	Success	127.0.0.1
2	2	2026-05-20 02:56:20.5640519	USR-CUST-001	Customer	SeedOrderCreated	Order	ORD-SAMPLE-001	Success	127.0.0.1
3	3	2026-05-20 09:36:35.4287577	USR-ADMIN-001	Admin	Login	User	USR-ADMIN-001	Success	::ffff:172.22.0.1
4	4	2026-05-20 09:36:35.8691753	USR-ADMIN-001	Admin	Login	User	USR-ADMIN-001	Success	::ffff:172.22.0.1
5	5	2026-05-20 09:37:50.8859304	USR-ADMIN-001	Admin	Login	User	USR-ADMIN-001	Failed	::ffff:172.22.0.1
6	6	2026-05-20 09:38:38.6289845	USR-ADMIN-001	Admin	Login	User	USR-ADMIN-001	Failed	::ffff:172.22.0.1
7	7	2026-05-21 02:31:14.4741039	anonymous	Guest	Login	User	NULL	Failed	::ffff:172.22.0.1
8	8	2026-05-21 02:31:41.2346161	USR-CUST-001	Customer	Login	User	USR-CUST-001	Success	::ffff:172.22.0.1
9	9	2026-05-21 02:31:52.5698477	USR-CUST-001	Customer	OrderInserted	Order	ORD-1779330712525	Success	172.22.0.3
10	10	2026-05-21 02:31:52.5698477	USR-CUST-001	Customer	ProductUpdated	Product	PRD-BAG-001	Success	172.22.0.3
11	11	2026-05-21 02:31:52.6813515	USR-CUST-001	Customer	OrderCreated	Order	ORD-1779330712525	Success	::ffff:172.22.0.1
12	12	2026-05-21 02:33:48.7316568	USR-CUST-001	Customer	OrderInserted	Order	ORD-1779330828728	Success	172.22.0.3
13	13	2026-05-21 02:33:48.7316568	USR-CUST-001	Customer	ProductUpdated	Product	PRD-BAG-001	Success	172.22.0.3
14	14	2026-05-21 02:33:48.7480843	USR-CUST-001	Customer	OrderCreated	Order	ORD-1779330828728	Success	::ffff:172.22.0.1

Figure 2.1.5 Sample record from AuditLog Table

3. Threat Modelling

Risk	Category	Example / Mitigation Description
Credential Spoofing via Login	S	An attacker attempts to impersonate an admin or inventory officer by guessing credentials. bcrypt password hashing, signed session cookies, and login rate limiting reduce this risk.
SQL Injection Data Tampering	T, I	An attacker enters malicious SQL into product or order fields. Parameterized queries and server-side validation prevent injected SQL from being executed.
Repudiation of Malicious Actions	R	A privileged user deletes or changes product records and denies the action. Audit logs and triggers make actions traceable.
Unauthorized Data Access	I	A lower-privileged user attempts to view full customer personal data. Dynamic Data Masking, SQL views, and least privilege roles limit exposure.
DoS via Resource Exhaustion	D	Attackers repeatedly submit login requests or large payloads. Rate limiting and request size limits reduce the attack impact.
Privilege Escalation via Exploit	E	A customer attempts to access admin product deletion or audit log functions. RBAC and SQL DENY permissions restrict unauthorized access.

Our system is protected from STRIDE and the following are the measures we took: As for the DREAD, the following are the measures done for compliance:

Risk	Category (STRIDE)	D	R	E	A	D	Threat Rating
Credential Spoofing via Login	S	7	7	6	8	7	7.0
SQL Injection Data Tampering	T, I	8	6	5	7	6	6.4
Repudiation of Malicious Actions	R	6	5	4	5	7	5.4
Unauthorized Data Access	I	8	5	5	8	6	6.4
DoS via Resource Exhaustion	D	7	6	6	8	7	6.8
Privilege Escalation via Exploit	E	7	5	5	6	6	5.8

4. PDPA 2010

4.1 Categorization with PDPA For Personnel

Customers

Category: Data Subjects

Description: Customers register and use the fashion e-commerce system by providing personal data such as name, email, phone number, address, and order details.

PDPA Relevance: Customers are the data subjects whose personal data must be collected, stored, processed, and protected according to PDPA 2010.

SecureStyle Company / Admin

Category: Data User

Description: The company determines why customer personal data is collected and how it is processed. Admin users manage system records and security logs.

PDPA Relevance: The data user is responsible for complying with PDPA principles and ensuring that personal data is protected.

Inventory Officers

Category: Authorized Personnel

Description: Inventory officers manage product records and may view limited customer delivery-related information when needed.

PDPA Relevance: Officers must only access data needed for their work and must not misuse customer personal data.

Developers / Server Administrators

Category: Data Processor / Data Intermediary

Description: Technical personnel maintain the application, database, server, backup, and security controls.

PDPA Relevance: They must protect data using access control, secure configuration, backup, and monitoring.

4.2 Data Lifecycle Mapping PDPA2010 Requirement

Data Collection

PDPA Requirement: Section 6(1) - Personal data must be collected for lawful and necessary purposes with notice and consent.

Compliance Actions: Inform customers why personal data such as name, email, phone number, address, and order information are collected during account registration and order placement. Obtain customer consent before processing data.

Responsible Personnel: Admin / Developers

Data Processing

PDPA Requirement: Section 6(3) - Personal data must be processed fairly and only for stated purposes.

Compliance Actions: Use customer data only for account management, order processing, delivery, and customer support purposes. Restrict processing access using role-based access control (RBAC).

Responsible Personnel: Admin / Inventory Officer

Data Storage

PDPA Requirement: Section 9(1) - Personal data must be protected against loss, misuse, modification, and unauthorized access.

Compliance Actions: Use bcrypt password hashing, SQL permissions, Dynamic Data Masking (DDM), Row-Level Security (RLS), backups, and Transparent Data Encryption (TDE) to secure stored data.

Responsible Personnel: Server Administrator

Data Access

PDPA Requirement: Section 30(1) - Data subjects have the right to access and correct their personal data.

Compliance Actions: Provide profile management or customer support processes that allow customers to review and update their personal information when necessary.

Responsible Personnel: Admin / Customer Support

Data Disclosure

PDPA Requirement: Section 6(2)(b) - Personal data should not be disclosed without consent unless required by law.

Compliance Actions: Share only necessary delivery-related data with authorized personnel or delivery parties. Prevent unauthorized disclosure using SQL permissions and least privilege access control.

Responsible Personnel: Admin

Data Retention

PDPA Requirement: Section 10(1) - Personal data must not be retained longer than necessary for fulfilment of its purpose.

Compliance Actions: Define retention periods for inactive accounts, audit logs, and completed orders. Remove or archive outdated records according to organizational policy.

Responsible Personnel: Admin / Server Administrator

Data Deletion

PDPA Requirement: Section 10(2) - Personal data must be securely deleted when no longer required.

Compliance Actions: Implement controlled deletion or anonymization procedures to securely remove personal data that is no longer needed.

Responsible Personnel: Server Administrator

5. Security Measures Implementation

The following security measures are implemented to protect the database from internal and external attacks:

Authentication and Authorization: Only authenticated users can access protected APIs. Authorization is based on user role.

Password Hashing: bcrypt is used to hash passwords before storing them in SQL Server.

Role-Based Access Control (RBAC): Customers can create orders, inventory officers can insert products, and admins can delete products and view audit logs.

SQL Server Roles: CustomerRole, InventoryOfficerRole, and AdminRole are created in SQL Server.

Views and Permissions: Views such as vw_ActiveProducts and vw_CustomersForStaff restrict what data users can query. GRANT and DENY permissions limit table access.

Row-Level Security (RLS): The order access policy restricts order rows based on the user context.

Dynamic Data Masking (DDM): Phone number, address, and shipping address fields are masked to reduce exposure of sensitive personal data.

SQL Injection Prevention: Parameterized queries are used in the backend for product, order, login, and audit operations.

Audit Logs: The AuditLog table records login, product, order, and security events for accountability.

Database Triggers: Triggers automatically log product updates and order inserts.

Input Validation: The backend validates request bodies using Zod schemas, preventing invalid product and order data.

Rate Limiting: Login attempts are rate-limited to reduce brute-force attacks.

Backup: The database backup command creates a recoverable backup file to support disaster recovery.

Encryption: TDE is included as a planned database-at-rest control. TLS should be used in deployment to protect data in transit.

